

Q1		Answer briefly:	
CO-1; SO-1; BL-2; U1	a.	How is motive, goal and objective related to Information Security Attacks and comment on any TWO Information Security Attack Vectors.	[05]
CO-1; SO-1; BL-2; U2	b.	Describe the SAMM Framework for assessing the Secure Software Lifecycle.	[05]
CO-3; SO-4; BL-3; U3	c.	Jot down the reasons for API Vulnerability.	[05]
CO-2; SO-1; BL-2; U5	d.	Infer BYOD Benefits.	[05]
Q2	a.	Working and Significance of MVC Architecture compared with Single-page Architecture.	[10]
CO-1; SO-1; BL-4; U1	b.	A web application executes the following query when retrieving user details: <pre>SELECT * FROM users WHERE username='username';</pre> The attacker cannot see query results but can infer delays in execution. A web application contains a login page where users enter their username and password. The server-side query executes: <pre>SELECT * FROM users WHERE username='username' AND password='password';</pre>	[10]
Q2			
CO-2; SO-1; BL-1; U4			

		The attacker cannot see direct SQL errors or outputs but can infer database responses based on application behaviour. - Identify the type of SQL injection attack and explain the attack comparing to other types of SQL query injection attacks. - Write the modified query after the attacker inputs the payload the username field with a time delay of 5 seconds. - How does the attacker determine if the application is vulnerable? - What are the requirements for this attack to be successful? - How can this attack be prevented?	
Q3 CO-2; SO-1; BL-3; U3	a.	Comment on static detection techniques and relate to how and which vulnerability they help detect.	[10]
Q3 CO-3; SO-4; BL-4; U4	b.	A financial web application allows users to fetch stock market data from external APIs. The API request is sent from the client's browser to the server, which fetches data from the provided URL. POST /finance/marketData HTTP/1.0 Content-Type: application/x-www-form-urlencoded Content-Length: 90 stockApi=http://data.marketfinance.com:8080/finance/marketData /checkcurrentTime - Identify which type of attack can be crafted by the attacker to check the contents of /etc/passwd on the server side. Explain the attack. - Rewrite the HTTP request to create an attack request. - What insight the attacker gains through the attack? - Ways to mitigate this attack. - Explain types of the identified attack.	[10]
Q4 CO-1; SO-1; BL-2; U2	a.	Explain the Objective and Applicability of NIST.	[10]
Q4 CO-2; SO-1; BL-1; U5	b.	An attacker wants to trick users into accidentally "Like" a post on SocialHub by exploiting a clickjacking vulnerability. The attacker creates a malicious page which contains the ability to click the "Like" button from SocialHub. - What would be the Attacker's Page Design (Malicious). Explain only the significant code. - What should be the design of web page on the server side (defensive page design of SocialHub). Explain only the significant code.	[10]
Q5	a.	How would runtime detection help in mitigating structured output generation vulnerabilities?	[10]

CO-2; SO-1; BL-2; U3			[10]
Q5 CO-3; SO-1; BL-1; U5	b.	Describe SS7 Vulnerability and Smishing.	
Q6 CO-1; SO-1; BL-4; U1	a.	Compare between DAST, IAST and SAST application security tools and solutions.	[10]
Q6 CO-2; SO-1; BL-1; U4	b.	Consider the HTTP Request Headers: POST / HTTP/1.1 Host: vulnerable-website Connection: keep-alive Content-Type: application/x-www-form-urlencoded Content-Length: _____ Transfer-Encoding: _____ i) Craft a HTTP post request which poisons the back-end server with the string "SMUGGLED" exploiting CL.TE vulnerability. ii) Write your analysis. iii) Compare between CL.TE, TE.CL and TE.TE.	[10]
Q7 CO-1; SO-1; BL-1; U2	a.	Explain the Objective and Applicability of NIST.	[10]
Q7 CO-3; SO-4; BL-4; U4	b.	A user is logged into their email service provider (e.g., MailSecure.com) and is composing an important email. The email service allows users to update their password through a simple web form. The password change request is processed using the following URL: GET http://mailsecure.com/updatePassword.do?newpassword=Attacker123 HTTP/1.1 An attacker wants to change the victim's password to "Attacker123", thereby locking the victim out of their own email account. i) Identify the attack and explain the attack. ii) What steps did the attacker incorporate to devise this attack? iii) What are the requirements for this attack to be successful? iv) What knowledge should a victim have to avoid such an attack? v) How can the bank prevent this attack?	[10]